

Vulnerability Assessment & Security Audit Report

Target Application: KryoSync – <https://kryosync.netlify.app>

Assessment Date: 15 – 16 June 2026

Assessed By: Mahek Oza

1. Executive Summary

This security audit was conducted on the web application `kryosync.netlify.app` to identify common web vulnerabilities, evaluate security posture, and recommend hardening measures. The assessment was performed using industry-standard, legal tools in a non-intrusive manner with prior authorization from the site owner.

Overall Risk Rating: Low

No critical vulnerabilities were discovered that would allow immediate compromise of user data or server infrastructure. The application benefits from Netlify's managed hosting environment, which provides default DDoS protection, TLS encryption, and CDN-level security. However, several configuration-level improvements are recommended to align with OWASP Top 10 and industry best practices.

2. Scope & Methodology

2.1 Scope

In-scope: Public-facing web application at `https://kryosync.netlify.app`

Out-of-scope: Netlify infrastructure, third-party APIs, source code review, social engineering.

2.2 Methodology

Testing followed the OWASP Web Security Testing Guide v4.2. Tools used:

1. *OWASP ZAP 2.14.0* – Automated spidering + active scan for XSS, SQLi, CSRF, and auth flaws.
2. *Mozilla Observatory* – Analysis of HTTP security headers.
3. *Qualys SSL Labs* – TLS/SSL implementation review.
4. *Manual Review* – Check for exposed files, directory listing, and information disclosure.

All testing was conducted in a controlled manner to avoid service disruption.

3. Detailed Findings

3.1 Finding #1: Missing Content-Security-Policy Header – Medium

Description: The application does not return a `Content-Security-Policy` header. CSP is a defense-in-depth mechanism that helps mitigate Cross-Site Scripting and data injection attacks by specifying which dynamic resources are allowed to load.

Evidence: Response headers from `GET /` show no CSP directive. Observatory Score: 65/100 “D”.

Business Impact: If an XSS vulnerability were introduced in future updates, the lack of CSP would allow full exploitation. Current impact is limited as no reflected/stored XSS was found.

Recommendation: Define a baseline CSP in `netlify.toml`:

```
[[headers]]
```

```
for = "/*"
```

```
[headers.values]
```

```
Content-Security-Policy = "default-src 'self'; script-src 'self' 'unsafe-inline'; object-src 'none';"
```

Start in `Content-Security-Policy-Report-Only` mode to test before enforcing.

3.2 Finding #2: Strict-Transport-Security Not Set – Low

Description: HSTS header is absent, meaning browsers do not force HTTPS for all future requests. While Netlify redirects HTTP→HTTPS by default, HSTS provides extra protection against SSL-stripping attacks.

Evidence: `curl -I https://kryosync.netlify.app` shows no `Strict-Transport-Security` header.

Recommendation: Add `Strict-Transport-Security: max-age=31536000; includeSubDomains; preload` to headers.

3.3 Finding #3: Client-Side JavaScript Library With Known CVE – Low

Description: The site loads `jquery@3.4.1` which is vulnerable to CVE-2020-11023 – Prototype Pollution.

Evidence: `/js/app.js` references jQuery 3.4.1. No exploit chain was identified as no user-controlled input is passed to vulnerable functions.

Recommendation: Update to `jquery@3.6.0+` via npm and redeploy. Use `npm audit fix` as part of CI/CD.

3.4 Positive Findings

1. *TLS Configuration*: A+ on SSL Labs. TLS 1.3 enabled, strong cipher suites, valid certificate.
2. *No Sensitive Data Exposure*: No `.env`, `.git`, or backup files found accessible.
3. *X-Frame-Options*: Present and set to `SAMEORIGIN`, mitigating clickjacking.

4. Risk Summary Matrix

Risk Level	Count	Key Issue
Critical	0	None
High	0	None
Medium	1	Missing CSP
Low	2	HSTS, Outdated jQuery

5. Recommendations & Next Steps

1. ***Short-term***: Implement CSP + HSTS headers. Update jQuery. Estimated effort: 2 hours.
2. ***Mid-term***: Integrate SAST/DAST into pipeline. Enable Netlify's built-in CSP nonce support.
3. ***Long-term***: Conduct annual penetration tests and add a `security.txt` file for responsible disclosure.

6. Conclusion

KryoSync demonstrates a solid baseline security posture typical of modern Jamstack applications on Netlify. The identified issues are configuration-related and do not pose immediate risk to users. Implementing the recommended headers and dependency updates will raise the application to an "A" rating on Mozilla Observatory and reduce attack surface against emerging client-side threats.